14. - Experiencia en el mundo real

Introducción

Experiencia en el mundo real

En este capítulo, se analiza la elección y configuración de adaptadores Wi-Fi y controladores para 2024, enfocándose en modelos recomendados que soportan bandas de 2.4 GHz, 5 GHz y 6 GHz. Se examinan opciones como la Alfa AWUS036AXML y la Panda PAU09 N600 en términos de protocolos, bandas y precios. Además, se detalla la instalación de controladores en Kali Linux, el uso de antenas direccionales para ampliar el alcance de la señal y las mejores prácticas para el wardriving, incluyendo el equipamiento necesario y el análisis de datos de redes Wi-Fi. Finalmente, se abordan vulnerabilidades comunes y sus soluciones para asegurar la integridad de las redes inalámbricas.

Adaptadores Wi-Fi y Controladores

Antenas Wi-Fi

Tarjetas Inalámbricas

Mejores Opciones Personales para 2024

Si tuviera que comprar una tarjeta inalámbrica hoy, elegiría una de las siguientes opciones, ya que son similares en precio y ofrecen soporte para 6 GHz, asegurando así su durabilidad a futuro.

Tarjeta Inalámbrica	Protocolos	Bandas Wi-Fi	Rango de Precio	Enlace
Alfa AWUS036AXML	a/b/g/n/ac/ax	2.4GHz, 5GHz, 6 GHz	€50 - €60	Amazon ES Amazon US
Alfa AWUS036AXM	a/b/g/n/ac/ax	2.4GHz, 5GHz, 6 GHz	€30 - €40	Amazon ES Amazon US

Alternativas Confiables

Para aquellos que no necesitan la tecnología más reciente de Wi-Fi 6E pero aún desean un rendimiento confiable:

Tarjeta Inalámbrica	Protocolos	Bandas Wi-Fi	Rango de Precio	Enlace
Alfa AWUS036ACH	a/b/g/n/ac	2.4GHz, 5 GHz	€50 - €60	Amazon ES Amazon US
Alfa AWUS036ACM	a/b/g/n/ac	2.4GHz, 5 GHz	€30 - €40	Amazon ES Amazon US
Panda PAU09 N600	a/b/g/n/ac	2.4GHz, 5 GHz	€60 - €80	Amazon ES Amazon US

Antena Direccional

Usar una antena direccional puede extender tu alcance y mejorar los resultados.

Antena Direccional	Rango de Precio	Enlace
Alfa APA-M25	€15 - €25	Amazon ES Amazon US

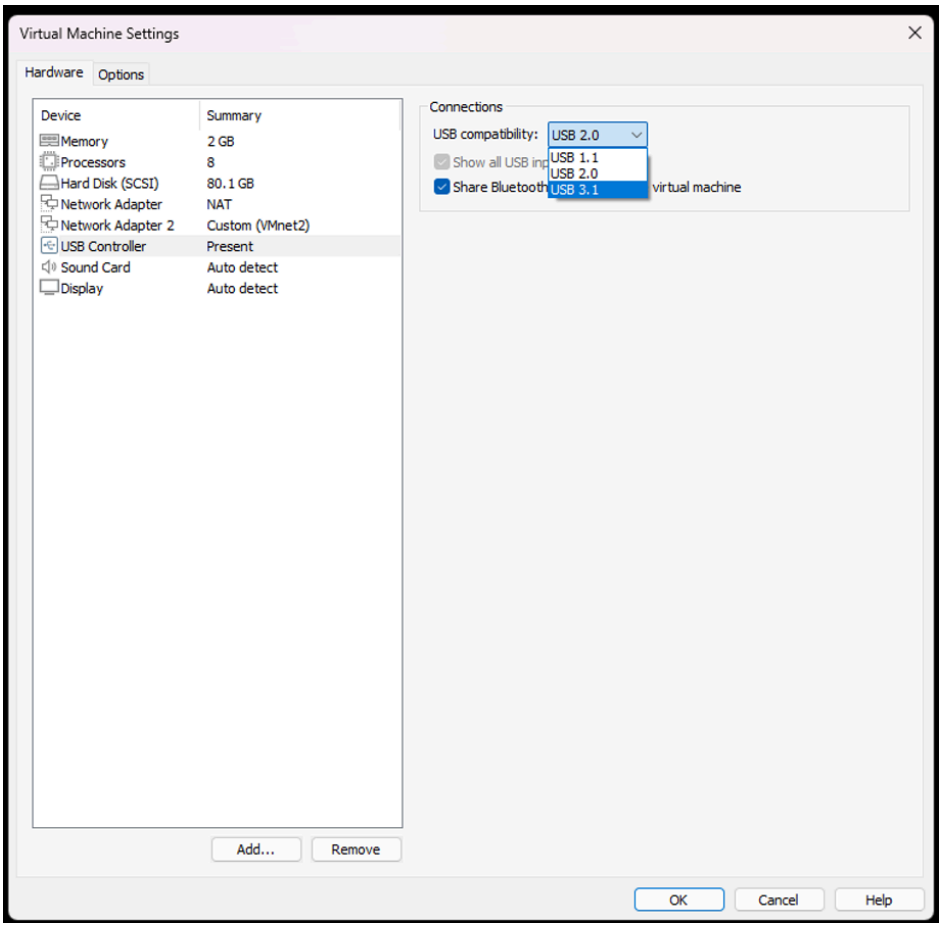
Instalación de Controladores en Kali Linux

Esta guía se basa en Kali Linux 2024.1 .

Habilitar USB 3.1 en tu VM

Asegúrate de que USB 3.1 esté habilitado en la configuración de tu máquina virtual:

- **VMware**:



Habilitar USB 3.1 en VMware

- **VirtualBox**: Primero, instala el Paquete de Extensión de VirtualBox.

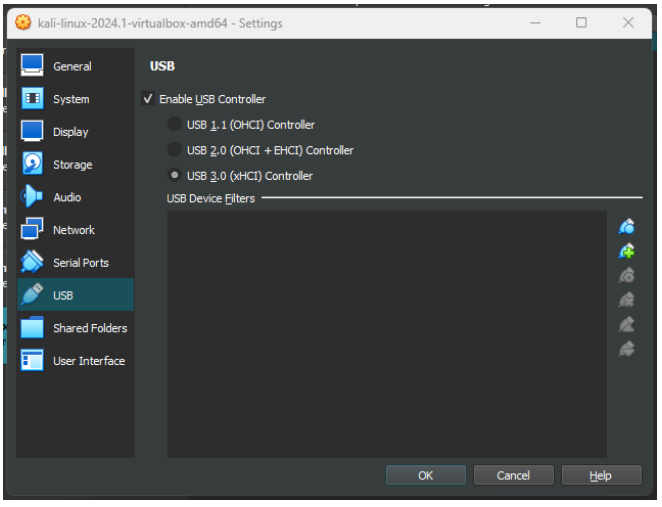
VirtualBox 7.0.18 Oracle VM VirtualBox Extension Pack

- All supported platforms

Support VirtualBox RDP, disk encryption, NVMe and PXE boot for Intel cards. See this chapter from the User Manual for an introduction to this Extension Pack. The Extension Pack binaries are released under the VirtualBox Personal Use and Evaluation License (PUEL). *Please install the same version extension pack as your installed version of VirtualBox.*

Instalar Extension pack

Luego, habilita USB 3.1:



USB 3.0 en VBox

Instalación de Controladores

Alfa AWUS036AXML

```
└─# lsusb
Bus 001 Device 001: ID 1d6b:0002 Linux Foundation 2.0 root hub
Bus 001 Device 002: ID 80ee:0021 VirtualBox USB Tablet
Bus 002 Device 001: ID 1d6b:0003 Linux Foundation 3.0 root hub
Bus 002 Device 002: ID 0e8d:7961 MediaTek Inc. Wireless_Device
```

Mediatek

- **Controlador**: MT7921AU
- **Fabricante**: Mediatek

Este dispositivo debería funcionar al conectarlo. Si Kali no lo detecta, ejecuta los siguientes comandos:

```
sudo apt-get install linux-headers-`uname -r`
reboot
```

Alfa AWUS036AXM

- **Controlador**: MT7921U
- **Fabricante**: Mediatek

Al igual que el modelo anterior, debería ser plug-and-play. Si no es detectado, sigue los mismos pasos.

Alfa AWUS036ACH

```
┌──(root㉿kali)-[/home/kali]
└─# lsusb
Bus 001 Device 001: ID 1d6b:0002 Linux Foundation 2.0 root hub
Bus 001 Device 002: ID 80ee:0021 VirtualBox USB Tablet
Bus 001 Device 003: ID 0bda:8812 Realtek Semiconductor Corp. RTL8812AU 802.11a/b/g/n/ac 2T2R DB WLAN Adapter
Bus 002 Device 001: ID 1d6b:0003 Linux Foundation 3.0 root hub
```

Realtek RTL8812AU

- **Controlador**: rtl8812au
- **Fabricante**: Realtek

Instala los controladores usando apt-get:

```
sudo apt-get install linux-headers-`uname -r`
sudo apt-get install dkms
sudo apt-get install realtek-rtl88xxau-dkms
reboot
```

Ahora, el sistema debería detectar el dispositivo:

```
┌──(root㉿kali)-[/home/kali]
└─# airmon-ng

PHY     Interface       Driver          Chipset

phy0    wlan0           88XXau          Realtek Semiconductor Corp. RTL8812AU 802.11a/b/g/n/ac 2T2R DB WLAN Adapter
```

Antena detectada

Verifica la inyección de paquetes:

```
aireplay-ng -9 wlan0
```

```
┌──(root㉿kali)-[/home/kali]
└─# aireplay-ng -9 wlan0
03:36:58  Trying broadcast probe requests...
03:36:58  Injection is working!
03:36:59  Found 23 APs
```

Inyección de paquetes correcta

Alternativamente, puedes instalar el controlador manualmente desde el repositorio de aircrack-ng:

```
sudo apt install dkms
git clone -b v5.6.4.2 https://github.com/aircrack-ng/rtl8812au.git
cd rtl*
make
sudo make install
```

Panda PAU09 N600

```
┌──(root㉿kali)-[/home/kali]
└─# lsusb
Bus 001 Device 001: ID 1d6b:0002 Linux Foundation 2.0 root hub
Bus 001 Device 002: ID 80ee:0021 VirtualBox USB Tablet
Bus 001 Device 004: ID 148f:5572 Ralink Technology, Corp. RT5572 Wireless Adapter
Bus 002 Device 001: ID 1d6b:0003 Linux Foundation 3.0 root hub
```

Ralink RT5572

- **Controlador**: RT5572
- **Fabricante**: Ralink

Este dispositivo debería ser realmente plug-and-play.

Uso de Airodump para Escanear

Configurar el Modo Monitor

```
# Detener el administrador de redes
systemctl stop networking.service
```

```
# Configurar el modo monitor
sudo ip link set wlan0 down
sudo iw wlan0 set monitor control
sudo ip link set wlan0 up
```

Monitorizar Bandas de 2.4GHz y 5 GHz

```
sudo airodump-ng -a --band ag wlan0 -w scan
```

Monitorizar Banda de 6 GHz

Esto solo funciona con AWUS036AXML y AWUS036AXM. Nota que el uso de 6 GHz aún no está muy extendido.

```
sudo airodump-ng -a -C 5935-7115 wlan0 -w scan
```

GPS para Wardriving

Para wardriving, la forma más sencilla es usar tu teléfono móvil con GPS y capacidades Wi-Fi, como la APP de WiGLE. Para una configuración más potente, utiliza una antena externa con un módulo USB GPS o conéctate a un móvil vía Bluetooth.

GPS USB	Rango de Precio	Enlace
GlobalSat BU-353-S4	€40 - €50	Amazon ES Amazon US
U-blox7	€10 - €15	Amazon ES Amazon US

Lista de No Recomendados

- **Alfa AWUS1900**: Inestable
- **Alfa AWUS036NHA**: Solo 2.4 GHz
- **Alfa AWUS036NH**: Solo 2.4 GHz

Desautenticación en el mundo real

En auditorias de seguridad Wi-Fi, es común usar comandos como aireplay-ng -0 0 -a [BSSID] para desautenticar a todos los dispositivos conectados a un punto de acceso, o aireplay-ng -0 0 -a [BSSID] -c [MAC] para desconectar solo a un cliente específico. Sin embargo, MDK4 ofrece una alternativa más potente y flexible. A continuación, se explica cómo hacer estos ataques con MDK4:

Para desautenticar a todos los clientes de un AP:

```
mdk4 wlan0 d -B [BSSID]
```

Para desautenticar a un solo cliente específico:

```
mdk4 wlan0 d -B [BSSID] -S [MAC]
```

Donde:

- [BSSID] es la dirección MAC del punto de acceso objetivo.
- [MAC] es la dirección MAC del cliente específico a desautenticar.

Consideraciones:

- **Probar en una Red Propia**: Es recomendable probar en una red controlada, ya que la efectividad del ataque de desautenticación puede variar.
- **Compatibilidad con WPA3 y PMF**: Las redes WPA3 con 802.11w (Protected Management Frames) impedirán este tipo de ataque. Algunas redes WPA/WPA2 también pueden tener esta protección en entornos empresariales.
- **Limitaciones de Chipset**: La eficacia del ataque puede depender del tipo de chipset Wi-Fi y de si soporta funciones como VIF (Virtual Interface Functionality).

Consejos útiles

Windows e iOS almacenan el CA la primera vez siempre

Tanto Windows como iOS tienden a almacenar el certificado de autenticación (CA) la primera vez que se conecta a una red Wi-Fi segura. Esto significa que el dispositivo confía en el SSL/TLS del punto de acceso, lo que puede ser explotado en ataques posteriores si no se gestionan adecuadamente las CA almacenadas. Se recomienda gestionar y limpiar regularmente los certificados almacenados para reducir riesgos de seguridad.

Ataques con una sola interfaz usando virtualización

Es posible llevar a cabo ataques durante un pentesting utilizando una sola interfaz de red Wi-Fi mediante técnicas de virtualización. Herramientas como airmon-ng permiten crear interfaces virtuales que pueden ser utilizadas simultáneamente para la captura y la inyección de paquetes. Un flujo común incluye poner la interfaz en modo monitor, crear una interfaz virtual y proceder con la inyección de paquetes o ataques de des autenticación para analizar la seguridad de la red.

Usa interfaces en modo monitor solo si es necesario

Un error común que muchas personas cometen, principalmente porque no suele causar problemas, es utilizar interfaces en modo monitor para propósitos innecesarios. Esto puede no causar problemas porque las herramientas configuran de forma automática las interfaces, pero, aun así, se recomienda siempre hacer las cosas correctamente y tener control sobre los cambios de interfaz.

Cuando se trata de monitorear el tráfico de otros clientes o recopilar información sobre otros clientes, el uso del modo monitor es necesario. Sin embargo, cuando se trata de conectarse directamente a un AP, crear un AP falso o escanear solo APs, el modo monitor no es necesario. Es importante diferenciar entre estos casos.

Modo monitor

- Monitorear tráfico Wi-Fi (airodump-ng, mdk4)
- Ataques de desautenticación (aireplay-ng)

Modo gestionado

- Conectarse a un AP (wpa_supplicant, wpa_sycophant, air-hammer, EAP_buster, wacker)
- Crear un AP (eaphammer, berate_ap)
- Escanear APs (nmcli)

Cierra el Network Manager si surgen problemas

En entornos de laboratorio ideales como WiFiChallenge Lab, NetworkManager generalmente no causa problemas. Sin embargo, con múltiples antenas, cuando las ponemos en modo monitor, NetworkManager aún puede interactuar con la antena. A veces, realiza escaneos de APs y cambia el canal en el que opera. Por eso, otra recomendación es detener NetworkManager en estas situaciones.

```
sudo systemctl stop NetworkManager
```

Wardriving

Introducción al Wardriving

El término wardriving proviene de la combinación de war dialing (una técnica antigua de hacking) y conducción. Se refiere a la práctica de buscar redes inalámbricas Wi-Fi mientras se está en un vehículo en movimiento, utilizando un ordenador portátil o un smartphone para detectar estas redes. Esta actividad implica mapear la ubicación de las redes Wi-Fi, analizar sus protocolos de seguridad y, a menudo, documentar esta información. Si bien el wardriving puede realizarse con fines maliciosos, como hackear redes no seguras, también se utiliza por razones legítimas como el mapeo del rendimiento de la red, la investigación y la auditoría de seguridad.

Cómo Funciona el Wardriving

- **Equipamiento y Software**: Las herramientas básicas para el wardriving incluyen un vehículo, un ordenador portátil o dispositivo móvil con capacidad Wi-Fi, una antena de alta ganancia para aumentar el rango de detección de señal Wi-Fi y software especializado que pueda registrar señales Wi-Fi. Herramientas de software populares incluyen NetStumbler para Windows, Kismet para Linux, y WiGLE para Android e iOS.
- **Detección y Registro**: A medida que el wardriver se desplaza, su equipo escanea continuamente en busca de señales Wi-Fi disponibles. Cuando se detecta una red, el software registra varios datos como el Identificador del Conjunto de Servicios (SSID), el tipo de cifrado (WEP, WPA, etc.), la intensidad de la señal y las coordenadas GPS si están disponibles.
- **Análisis y Mapeo**: Los datos recopilados pueden analizarse con diversos propósitos. Un uso común es mapear la distribución de redes Wi-Fi en un área, lo que puede mostrar la densidad de redes, los protocolos de seguridad predominantes y redes potencialmente vulnerables. Herramientas como WiGLE permiten a los usuarios contribuir con sus hallazgos a un mapa global de redes Wi-Fi.

Wigle

WiGLE es una plataforma que permite a los usuarios compartir y visualizar redes Wi-Fi detectadas durante actividades de wardriving. Esta plataforma ofrece una base de datos global de ubicaciones y detalles de redes Wi-Fi, permitiendo el análisis de tendencia y la identificación de puntos débiles.

Registro en WiGLE

- Crear una cuenta en WiGLE.net
- Descargar las aplicaciones disponibles para Android e iOS

Uso de la Aplicación WiGLE

- Instalar y configurar la aplicación WiGLE en un dispositivo móvil
- Realizar escaneos mientras se conduce o se camina
- Subir los datos recopilados a la base de datos de WiGLE

Análisis en WiGLE

- Usar la plataforma para analizar densidades de red y tipos de cifrado utilizados
- Identificar redes no seguras o mal configuradas
- Contribuir al mapeo global de redes Wi-Fi para investigación

---

Checklist

En este apartado vamos a ver un ejemplo dechecklist para enfrentarse a una auditoría Wi-Fi. Estechecklist está diseñado para ayudar a identificar y mitigar las vulnerabilidades más comunes en redes Wi-Fi, proporcionando soluciones prácticas y efectivas para cada una. Esta herramienta es esencial para asegurar la robustez y seguridad de las redes inalámbricas en cualquier entorno.

Checklist Antes de comenzar

- Obtener los permisos necesarios
- Verificar Adaptadores Wi-Fi y sus Drivers. Generalmente se utilizan 2 adaptadores externos y el incorporado en el ordenador portátil, ya sea mediante una USB en vivo o directamente con Linux.
- Configurar y probar todos los equipos y herramientas
- Asegurarse de que las baterías y fuentes de alimentación estén completamente cargadas en el caso de que se vaya a hacer más orientado a Red Team (sin apoyo del cliente)

Checklist de Vulnerabilidades de Configuración y Soluciones

A continuación, se presenta una lista de posibles vulnerabilidades en la configuración de las redes Wi-Fi, junto con las soluciones recomendadas para mitigarlas. Esta lista está dividida en diferentes categorías según el tipo de red y las tecnologías empleadas.

Vulnerabilidades Generales para Todas las Redes Wi-Fi

- **Protección de Tramas de Gestión Deshabilitada (MFP):**
  - **Vulnerabilidad:** Tramas de des autenticación y des asociación no protegidas.
  - **Solución:** Habilitar la Protección de Tramas de Gestión (MFP) en el punto de acceso para proteger contra estos tipos de ataques. Esto ayuda a evitar la desconexión no autorizada de clientes legítimos de la red.
- **Exceso de Rango de Cobertura:**
  - **Vulnerabilidad:** Señal Wi-Fi extendida más allá de las áreas necesarias, permitiendo a atacantes potenciales conectarse desde fuera de las instalaciones.
  - **Solución:** Ajustar la potencia de transmisión de los puntos de acceso para limitar la cobertura solo a las áreas necesarias. Realizar un estudio de sitio para optimizar la cobertura.
- **Redes Ocultas:**
  - **Vulnerabilidad:** Redes Wi-Fi ocultas que no transmiten su SSID pueden ser detectadas y atacadas por métodos avanzados.
  - **Solución:** Evaluar la necesidad de ocultar el SSID y, si se decide ocultarlo, combinarlo con otras medidas de seguridad robustas como WPA3 para dificultar los ataques.
- **Falta de Aislamiento de Clientes** (Client Isolation)**:**
  - **Vulnerabilidad:** Usuarios pueden comunicarse directamente entre sí dentro de la misma red, lo que puede llevar a ataques internos.
  - **Solución:** Habilitar la función de aislamiento de clientes en el punto de acceso para evitar la comunicación directa entre dispositivos, reduciendo así el riesgo de ataques entre usuarios de la misma red.
- **Clientes con Probes Peligrosos:**
  - **Vulnerabilidad:** Dispositivos que envían solicitudes de probe a múltiples SSID, exponiéndose a ataques de rogue AP (punto de acceso falso).
  - **Solución:** Configurar dispositivos para evitar probes a SSID no conocidos y educar a los usuarios sobre la importancia de conectarse solo a redes de confianza.
- **SSID Genéricos:**
  - **Vulnerabilidad:** Uso de SSID predeterminados o comunes que pueden ser objetivos fáciles para atacantes.
  - **Solución:** Utilizar SSID únicos y no reveladores de la naturaleza o ubicación de la red para dificultar su identificación por parte de atacantes.
- **Ausencia de WIDS** (Wireless Intrusion Detection System)**:**
  - **Vulnerabilidad:** Ausencia de un sistema de detección de intrusiones que monitoree y alerte sobre actividades sospechosas en la red.
  - **Solución:** Implementar y configurar un WIDS para monitorear el tráfico y detectar posibles intrusiones o comportamientos anómalos, proporcionando una capa adicional de seguridad.

Vulnerabilidades en Redes OPN (Open Networks)

- **Red Abierta sin Cifrado (OPN):**
  - **Vulnerabilidad:** Los clientes de la red envían la información sin cifrar hacia el AP, lo que permite que cualquier atacante pueda ver la información en texto claro.
  - **Solución:** Si es necesario que la red no tenga autenticación, implementar OWE para cifrar la comunicación de los clientes. Si se pueden utilizar credenciales, implementar WPA3 con cifrado SAE o, como mínimo, WPA2 con PSK para asegurar que solo usuarios autorizados puedan acceder.
- **Información Sensible en Mensajes sin Cifrar:**
  - **Vulnerabilidad:** Tráfico sensible de red sin cifrar.
  - **Solución:** Implementar OWE y utilizar protocolos seguros como TLS o HTTPS para proteger la información sensible transmitida.
- **Portal cautivo sin TLS:**
  - **Vulnerabilidad:** Tráfico del login del portal cautivo sin cifrar.
  - **Solución:** Utilizar protocolos seguros como TLS o HTTPS para proteger la información sensible transmitida.
- **Acceso a Otros Segmentos de Red:**
  - **Vulnerabilidad:** Usuarios no autorizados pueden acceder a otros segmentos de la red, especialmente desde la red de invitados a la red interna.
  - **Solución:** Segmentar la red con VLANs y aplicar reglas estrictas de firewall para controlar el acceso entre segmentos, asegurando que los usuarios de la red de invitados no puedan acceder a recursos internos.
- **Debilidades del Portal Cautivo:**
  - **Vulnerabilidad:** Fallos en la implementación de portales cautivos pueden permitir el acceso no autorizado explotando el portal web.
  - **Solución:** Asegurar que el portal cautivo esté correctamente configurado y actualizado con las últimas medidas de seguridad. Realizar auditorías periódicas para identificar y corregir vulnerabilidades.
- **Bypass de Portal Cautivo:**
  - **Vulnerabilidad:** Técnicas que permiten a los usuarios evitar la autenticación del portal cautivo a nivel de red.
  - **Solución:** Implementar medidas adicionales de autenticación y monitoreo para detectar y prevenir intentos de bypass.

Vulnerabilidades en Redes OWE (Opportunistic Wireless Encryption)

- **Compatibilidad de Dispositivos:**
  - **Vulnerabilidad:** Dispositivos que no soportan OWE, forzando a caer a una red sin cifrar.
  - **Solución:** Asegurarse de que todos los dispositivos en la red soporten OWE y actualizar o reemplazar los dispositivos que no lo hagan para mantener la integridad de la seguridad de la red.

Vulnerabilidades en Redes WEP (Wired Equivalent Privacy)

- **Configuración de Claves WEP Estáticas y Débiles:**
  - **Vulnerabilidad:** Claves de cifrado fácilmente crackeables con herramientas de fuerza bruta.
  - **Solución:** Migrar a un protocolo de seguridad más robusto como WPA3 o WPA2 para garantizar una protección adecuada.
- **Uso Continuo de WEP:**
  - **Vulnerabilidad:** Uso de WEP, que es inherentemente inseguro.
  - **Solución:** Actualizar a WPA3 o WPA2 lo antes posible, ya que WEP no ofrece un nivel de seguridad aceptable en la actualidad.

Vulnerabilidades en Redes PSK (Pre-Shared Key) y SAE (Simultaneous Authentication of Equals)

- **Clave Precompartida Débil (PSK):**
  - **Vulnerabilidad:** Uso de contraseñas fáciles de adivinar o predecibles.
  - **Solución:** Implementar una política de contraseñas fuertes que incluya una combinación de letras, números y caracteres especiales. Cambiar las contraseñas regularmente para mantener la seguridad.
- **No Rotación de Claves (PSK):**
  - **Vulnerabilidad:** Uso prolongado de la misma clave sin cambios periódicos.
  - **Solución:** Establecer un calendario regular para cambiar las claves precompartidas y notificar a los usuarios de antemano para evitar interrupciones en el servicio.
- **Configuración Incorrecta de SAE:**
  - **Vulnerabilidad:** Errores en la configuración del protocolo SAE.
  - **Solución:** Verificar y asegurar que la configuración de WPA3 utiliza el protocolo SAE correctamente, revisando la documentación del fabricante y realizando pruebas de seguridad.
- **Compatibilidad de Dispositivos (SAE):**
  - **Vulnerabilidad:** Dispositivos que no soportan correctamente SAE.
  - **Solución:** Asegurarse de que todos los dispositivos en la red soporten SAE y actualizar o reemplazar los dispositivos que no lo hagan, garantizando la compatibilidad con los estándares de seguridad más recientes.

- **Filtrado de MAC Deshabilitado:**
  - **Vulnerabilidad:** No se está utilizando el filtrado de direcciones MAC para restringir el acceso a la red.
  - **Solución:** Implementar el filtrado de direcciones MAC para permitir solo dispositivos autorizados en la red, mejorando el control de acceso.
- **Rogue AP para Phishing de Contraseñas:**
  - **Vulnerabilidad:** Puntos de acceso falsos utilizados para engañar a los usuarios y obtener sus contraseñas.
  - **Solución:** Implementar un WIDS para detectar y alertar sobre puntos de acceso falsos. Educar a los usuarios sobre los peligros de conectarse a redes no verificadas para prevenir ataques de phishing.
- **Obtención de Información Sensible en Descifrado de Tráfico:**
  - **Vulnerabilidad:** Tráfico descifrado que puede contener información sensible.
  - **Solución:** Utilizar cifrado de extremo a extremo (como HTTPS) para proteger la información sensible transmitida sobre la red Wi-Fi, asegurando que los datos permanezcan seguros durante su tránsito.

Vulnerabilidades en Redes MGT (Management Frames Protection)

- **Bloqueo de Cuentas por Fuerza Bruta o Password Spraying:**
  - **Vulnerabilidad:** No hay un mecanismo para bloquear cuentas después de múltiples intentos fallidos.
  - **Solución:** Implementar políticas de bloqueo de cuentas después de un número determinado de intentos fallidos, reduciendo el riesgo de ataques de fuerza bruta.
- **No Uso de Identidades Anónimas:**
  - **Vulnerabilidad:** Uso de identidades reales en lugar de anónimas puede llevar a la exposición de información sensible.
  - **Solución:** Configurar identidades anónimas para el uso en autenticación de red cuando sea posible, protegiendo la privacidad de los usuarios.
- **Relay de Credenciales:**
  - **Vulnerabilidad:** Ataques de retransmisión de credenciales para obtener acceso no autorizado.
  - **Solución:** Utilizar autenticación mutua y cifrado fuerte para evitar ataques de retransmisión, asegurando que las credenciales no puedan ser reutilizadas por atacantes.
- **Rogue AP ya que los Clientes no Verifican CA:**
  - **Vulnerabilidad:** Clientes que no verifican la autenticidad del certificado del punto de acceso pueden conectarse a rogue APs.
  - **Solución:** Configurar clientes para que verifiquen siempre los certificados de los puntos de acceso y utilicen certificados firmados por una CA confiable para garantizar la autenticidad de las conexiones.
- **Phishing de Credenciales Mediante APs Falsos:**
  - **Vulnerabilidad**: APs falsos utilizados para engañar a los usuarios y obtener sus credenciales de acceso.
  - **Solución**: Implementar WIDS y educar a los usuarios sobre los peligros de conectarse a redes no verificadas. Utilizar autenticación multifactor para mitigar el riesgo de phishing.
- **Realización de ataques ESSID Stripping**:
  - **Vulnerabilidad**: Los atacantes pueden realizar ataques de stripping del ESSID para engañar a los clientes y hacer que se conecten a puntos de acceso falsos.
  - **Solución**: Configurar los clientes y puntos de acceso para que verifiquen siempre la autenticidad del ESSID y utilicen certificados firmados por una CA confiable. Implementar medidas de seguridad adicionales como WPA3 y educar a los usuarios sobre la importancia de conectarse solo a redes de confianza.
- **Interfaces de Administración por Defecto:**
  - **Vulnerabilidad:** Uso de configuraciones de administración por defecto que pueden ser conocidas por atacantes.
  - **Solución:** Cambiar las credenciales de administración por defecto y deshabilitar accesos innecesarios, asegurando que solo personal autorizado pueda realizar cambios en la configuración de la red.

Estructura del Informe

Este apartado trata sobre cómo estructurar, qué incluir y las mejores prácticas para crear un informe de pentesting (pruebas de penetración) para redes Wi-Fi de manera efectiva. Un buen informe no solo ayuda a entender los problemas encontrados, sino que también ofrece una guía clara sobre cómo mejorar la seguridad.

Estructura del Informe

Para que el informe de pentesting de redes Wi-Fi sea fácil de entender y útil, debe seguir una estructura clara. Aquí tienes una sugerencia de cómo hacerlo:

1. Portada

- **Título del Informe:** Informe de Pentesting de Redes Wi-Fi
- **Cliente:** Nombre de la empresa o persona para quien se hizo el trabajo
- **Fecha:** Fecha de entrega del informe
- **Autor:** Nombre del pentester o equipo que hizo el trabajo

2. Índice

Un índice detallado para que sea fácil encontrar lo que buscas en el informe.

3. Resumen Ejecutivo

- **Propósito del Pentesting:** Una breve explicación de por qué se hizo el pentesting.
- **Alcance del Pentesting:** Qué partes de la red Wi-Fi se evaluaron, incluyendo ubicaciones y segmentos específicos.
- **Metodología:** Un resumen de las técnicas y herramientas que se usaron.
- **Principales Hallazgos:** Un resumen de las vulnerabilidades más importantes que se encontraron.
- **Análisis General:** Una evaluación general del estado de seguridad de la red Wi-Fi.
- **Recomendaciones:** Un resumen de las acciones sugeridas para corregir los problemas.

4. Alcance y Metodología

- **Alcance del Trabajo:** Detalles sobre las redes Wi-Fi que se evaluaron, incluyendo SSIDs y ubicaciones.
- **Metodología Utilizada:** Una descripción detallada de las técnicas y herramientas empleadas, tales como:
  - Escaneo de redes
  - Captura de paquetes
  - Análisis de configuraciones de seguridad
  - Pruebas de autenticación y cifrado

Para este pentesting, se utilizó la metodología OSSTMM (Open Source Security Testing Methodology Manual). Esta metodología proporciona un marco estructurado para evaluar la seguridad de redes y sistemas, asegurando que las pruebas sean exhaustivas, replicables y basadas en estándares reconocidos. Utilizar OSSTMM garantiza que el análisis sea riguroso y que las recomendaciones sean precisas y efectivas para mejorar la seguridad de la red Wi-Fi evaluada.

5. Detalles de los Hallazgos

Cada hallazgo debe ser documentado de manera detallada, incluyendo:

- **Descripción de la Vulnerabilidad:** Una explicación clara de la vulnerabilidad encontrada.
- **Impacto Potencial:** Qué tan grave podría ser si alguien explotara esta vulnerabilidad.
- **Evidencia:** Capturas de pantalla, logs y otros datos que demuestren el hallazgo.
- **Recomendaciones:** Acciones sugeridas para solucionar el problema, clasificadas por prioridad.

Ejemplo de formato para un hallazgo:

Vulnerabilidad	**Contraseña Débil WPA2-PSK**
Descripción	La red Wi-Fi **wifi-mobile** usa una contraseña débil.
Impacto Potencial	Un atacante podría romper la contraseña con fuerza bruta, obteniendo acceso no autorizado a la red.
Evidencia	Captura de pantalla del intento exitoso de crackeo.
Recomendaciones	Cambiar a una contraseña más fuerte y utilizar WPA3 si es posible.

6. Recomendaciones Generales

- **Mejoras en la Configuración:** Sugerencias para mejorar las configuraciones de seguridad de la red Wi-Fi.
- **Capacitación y Concienciación:** Recomendaciones sobre la capacitación del personal en prácticas de seguridad.
- **Políticas de Seguridad:** Sugerencias para implementar o mejorar políticas de seguridad de redes Wi-Fi.

7. Anexos

- **Herramientas Utilizadas:** Lista de herramientas de pentesting utilizadas, como aircrack-ng, Wireshark, etc.
- **Referencias:** Documentación adicional, guías de configuración y recursos utilizados para el informe.
- **Glosario de Términos:** Definiciones de términos técnicos utilizados en el informe.

Mejores Prácticas para la Creación del Informe

- **Claridad y Concisión:** Usa un lenguaje claro y evita jerga técnica innecesaria.
- **Evidencia Visual:** Incluye capturas de pantalla, diagramas y logs para respaldar los hallazgos.
- **Prioriza las Recomendaciones:** Clasifica las recomendaciones según la gravedad de las vulnerabilidades.
- **Revisiones y Validaciones:** Realiza revisiones internas del informe para asegurar su precisión y completitud.
- **Confidencialidad:**Asegúrate de que el informe sea tratado de manera confidencial y solo accesible para personas autorizadas.

Virtualización de interfaces

Al trabajar con redes inalámbricas en Linux a menudo surge la necesidad de realizar varias tareas a la vez con hardware limitado. Por ejemplo crear un Punto de Acceso (AP) y al mismo tiempo capturar tráfico en modo monitor usando una sola interfaz Wi-Fi. La funcionalidad de **interfaces virtuales** en Linux permite generar varias interfaces lógicas a partir de una única interfaz física.

Este tipo de virtualización no funciona completamente en el laboratorio porque las interfaces ya están virtualizadas.

Creación de interfaces virtuales

Usando la herramienta iw podemos añadir dos interfaces sobre `wlan0`: una para actuar como AP y otra en modo monitor.

```
iw dev wlan0 interface add wlan0_ap type ap addr 12:34:56:78:ab:cd
iw dev wlan0 interface add wlan0_mon type monitor addr 12:34:56:78:ab:ce
```

- iw dev wlan0 interface add añade la interfaz virtual
- wlan0_ap funcionará como AP
- wlan0_mon estará en modo monitor
- type ap y type monitor definen el modo
- addr asigna MAC distintas para evitar conflictos

```
root@WiFiChallengeLab:/home/user# iw dev wlan0 interface add wlan0_ap type managed addr 12:34:56:78:ab:cd
root@WiFiChallengeLab:/home/user# iw dev wlan0 interface add wlan0_mon type monitor addr 12:34:56:78:ab:ce
root@WiFiChallengeLab:/home/user#
root@WiFiChallengeLab:/home/user# airmon-ng

PHY     Interface       Driver          Chipset

phy0    wlan0           mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
phy0    wlan0_ap        mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
phy0    wlan0_mon       mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
phy1    wlan1           mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
phy2    wlan2           mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
phy3    wlan3           mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
phy4    wlan4           mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
phy5    wlan5           mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
phy6    wlan6           mac80211_hwsim  Software simulator of 802.11 radio(s) for mac80211
```

creación de interfaces virtuales

```
root@WiFiChallengeLab:/home/user# iwconfig wlan0
wlan0     IEEE 802.11  ESSID:off/any
          Mode:Managed  Access Point: Not-Associated   Tx-Power=20 dBm
          Retry short limit:7   RTS thr:off   Fragment thr:off
          Encryption key:off
          Power Management:on

root@WiFiChallengeLab:/home/user# iwconfig wlan0_ap
wlan0_ap  IEEE 802.11  ESSID:off/any
          Mode:Managed  Access Point: Not-Associated   Tx-Power=20 dBm
          Retry short limit:7   RTS thr:off   Fragment thr:off
          Encryption key:off
          Power Management:on

root@WiFiChallengeLab:/home/user# iwconfig wlan0_mon
wlan0_mon  IEEE 802.11  Mode:Monitor  Tx-Power=20 dBm
          Retry short limit:7   RTS thr:off   Fragment thr:off
          Power Management:on
```

listado con ip link

Comprobación de compatibilidad

Antes de proceder verifica que tu tarjeta Wi-Fi soporta virtualización.

```
iw list | grep -A5 "Supported interface modes"
iw list | grep -A10 "valid interface combinations"
```

Debes ver AP y monitor en Supported interface modes y una línea en valid interface combinations que permita ambos roles simultáneos. Si falta alguno el driver o firmware no admitirá esta configuración.

```
user@WiFiChallengeLab:~$ iw list  | grep 'Supported interface modes' -A 10
        Supported interface modes:
                 * IBSS
                 * managed
                 * AP
                 * AP/VLAN
                 * monitor
                 * mesh point
                 * P2P-client
                 * P2P-GO
                 * P2P-device
```

ejemplo sin modo AP en "Supported interface modes"

```
user@WiFiChallengeLab:~$ iw list | grep -A10 "valid interface combinations"
        valid interface combinations:
                 * #{ IBSS } <= 1, #{ managed, AP, mesh point, P2P-client, P2P-GO } <= 2048, #{ P2P-device } <= 1,
                   total <= 2050, #channels <= 1, radar detect widths: { 20 MHz (no HT), 20 MHz, 40 MHz, 80 MHz, 160 MH
z }

        HT Capability overrides:
                 * MCS: ff ff ff ff ff ff ff ff ff ff
                 * maximum A-MSDU length
                 * supported channel width
                 * short GI for 40 MHz
                 * max A-MPDU length exponent
                 * min MPDU start spacing
```

ejemplo sin modo AP en "valid interface combinations"

- #{ IBSS } <= 1, significa que puedes crear como máximo una interfaz IBSS (ad hoc)
- #{ managed, AP, mesh point, P2P-client, P2P-GO } <= 2048, significa que puedes tener hasta 2048 interfaces en cualquier combinación de modo estación managed, punto de acceso AP, mesh point, cliente P2P-client o propietario de grupo P2P-GO
- #{ P2P-device } <= 1, significa que puedes crear como máximo una interfaz P2P-device
- total <= 2050, significa que la suma de todas las interfaces virtuales no puede exceder 2050
- `#channels` <= 1, significa que todas las interfaces deben operar simultáneamente en el mismo canal
- radar detect widths: { 20 MHz (no HT), 20 MHz, 40 MHz, 80 MHz, 160 MHz }, lista los anchos de banda de canal en los que se admite detección de radar

Aplicaciones prácticas y puntos a recordar

- Levantar un AP cautivo con wlan0_ap mientras capturas tráfico en wlan0_mon
- Realizar ataques de desautenticación con aireplay-ng sin detener el AP
- El límite `#channels` <= 1 indica que ambas interfaces deben permanecer en el mismo canal
- Si cambias de canal con airodump-ng --channel … todas las interfaces saltarán también
- No notarás impacto serio salvo tráfico muy intenso aun así monitoriza con htop o iftop

Con estos pasos podrás multiplicar las funciones de tu tarjeta Wi-Fi sin añadir hardware nuevo.

Extracción de Credenciales Wi-Fi

Esta guía explica paso a paso cómo recuperar contraseñas Wi-Fi guardadas en varios sistemas operativos.

1. Windows

1. Abre el Símbolo del sistema como Administrador.
2. Lista las redes Wi-Fi guardadas:

```
netsh wlan show profiles
```

3. Muestra las credenciales de una red específica:

```
netsh wlan show profile "NOMBRE_SSID" key=clear
```

4. Ubica tu contraseña en el campo Contenido de la clave.

2. Linux

1. Abre una terminal.
2. Navega al directorio de NetworkManager :

```
cd /etc/NetworkManager/system-connections/
```

3. Lee los archivos de credenciales Wi-Fi (requiere permisos de root):

```
sudo cat NOMBRE_SSID.nmconnection
```

4. Encuentra tu contraseña después de psk= o password=.

Asegúrate de tener acceso root para ejecutar comandos en Linux.

3. macOS

1. Abre la Terminal.
2. Usa el comando security para listar las credenciales:

```
security find-generic-password -ga "NOMBRE_SSID"
```

3. Introduce la contraseña de tu Mac si se te solicita.
4. Tu contraseña Wi-Fi aparecerá entre comillas junto a password:.

4. Android

Esta guía es para Android 10 o superior.

1. Ve a Ajustes > Red e Internet > Wi-Fi.
2. Selecciona la red a la que estás conectado y haz clic en Compartir.
3. Autentícate con huella digital o contraseña.
4. La contraseña aparece debajo del código QR generado o dentro del propio QR. Puedes escanearlo con otro teléfono.

En dispositivos con root, puedes encontrar las contraseñas en `/data/misc/wifi/wpa_supplicant.conf`.

5. iOS

Esta guía es para iOS 16 o superior.

1. Ve a Ajustes > Wi-Fi.
2. Toca el icono ⓘ junto a tu red Wi-Fi .
3. Toca Contraseña y autentícate con Face ID, Touch ID o código de acceso.
4. La contraseña se mostrará claramente.

Para versiones anteriores de iOS, utiliza la sincronización con el Llavero de Mac para acceder a las contraseñas.